20. Secure Sensitive Data (GDPR/HIPAA)

Key Terms:

Term	Full Name	What it does
GDPR	General Data Protection Regulation	EU privacy law for personal data
HIPAA	Health Insurance Portability and Accountability Act	US healthcare data privacy law
PII	Personally Identifiable Information	Data that identifies individuals (name, SSN, email)
PHI	Protected Health Information	Medical records and health data
PCI-DSS	Payment Card Industry Data Security Standard	Credit card data protection
HSM	Hardware Security Module	Tamper-resistant device for cryptographic keys
AES-256	Advanced Encryption Standard 256-bit	Strong symmetric encryption algorithm
RBAC	Role-Based Access Control	Permissions assigned by role (admin, user)
ABAC	Attribute-Based Access Control	Permissions based on attributes (department, time)
DEK	Data Encryption Key	Key that encrypts actual data (encrypted by master key)
TLS	Transport Layer Security	Encryption for data in transit
OIDC	OpenID Connect	Authentication layer on top of OAuth 2.0

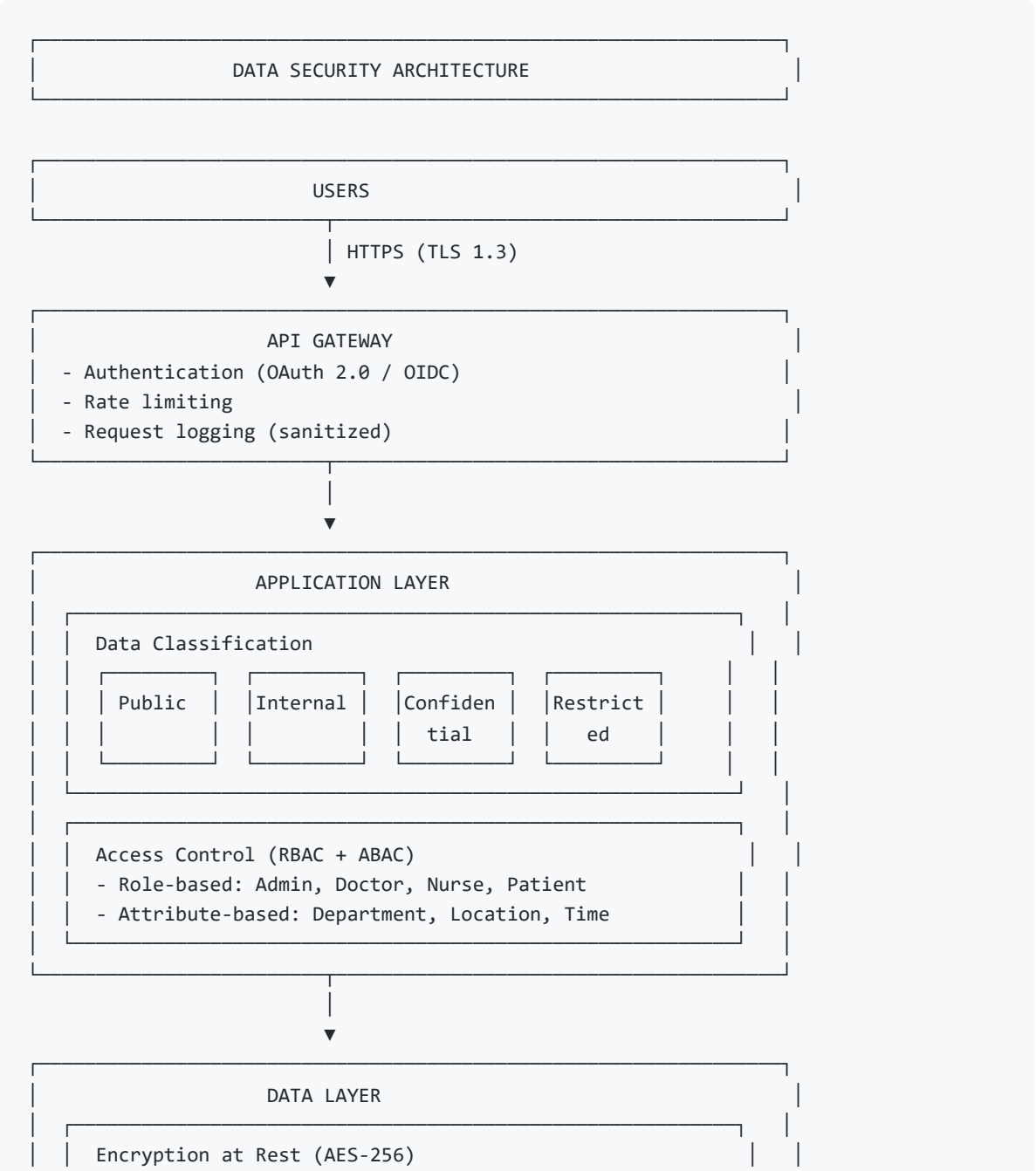
Problem Statement

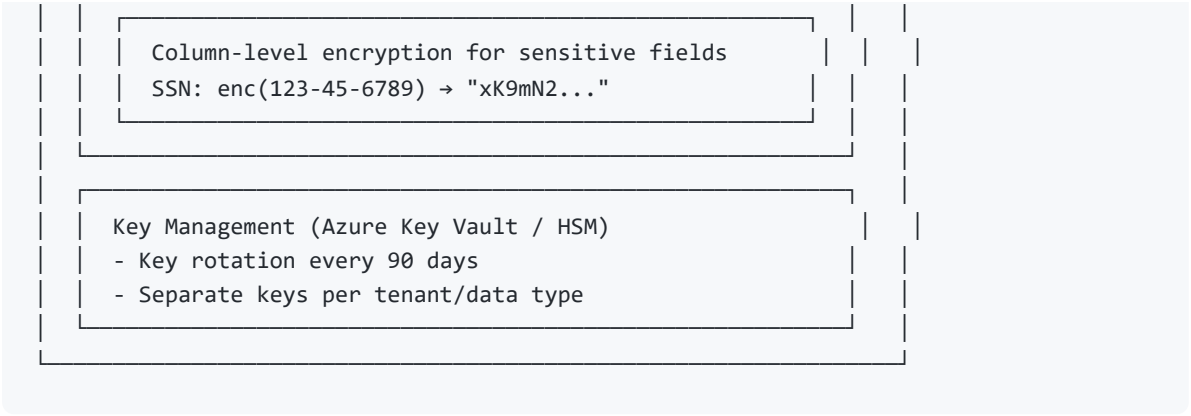
Design a system that securely handles sensitive data while complying with GDPR, HIPAA, and other privacy regulations.

Clarifying Questions to Ask

1. **Data types**: PII, PHI, financial, or all?
2. **Regulations**: Which compliance frameworks? (GDPR, HIPAA, PCI-DSS?)
3. **Geography**: Where are users and data located?
4. **Retention**: How long to keep data? Right to deletion?
5. **Access**: Who needs access? Audit requirements?
6. **Encryption**: At rest, in transit, or end-to-end?
7. **Breach**: Notification requirements?

High-Level Design





API Design

Data Subject Rights APIs (GDPR)

Method	Endpoint	Description
`GET`	`/api/v1/data-subjects/{userId}/export`	Export all user data (Right of Access)
`DELETE`	`/api/v1/data-subjects/{userId}`	Delete all user data (Right to Erasure)
`PUT`	`/api/v1/data-subjects/{userId}/consent`	Update consent preferences
`GET`	`/api/v1/data-subjects/{userId}/consent`	Get current consent status
`POST`	`/api/v1/data-subjects/{userId}/portability`	Request data portability export

Encryption & Key Management APIs

Method	Endpoint	Description
`POST`	`/api/v1/keys/rotate`	Trigger key rotation
`GET`	`/api/v1/keys/status`	Get encryption key status
`POST`	`/api/v1/encrypt`	Encrypt sensitive field
`POST`	`/api/v1/decrypt`	Decrypt sensitive field (audit-logged)

Audit APIs

Method	Endpoint	Description

`GET`	`/api/v1/audit/logs?resource={type}&from={date}`	Query audit logs
`GET`	`/api/v1/audit/access/{userId}`	Get access history for a user
`POST`	`/api/v1/audit/report`	Generate compliance report

Key Security Controls

```
1. ENCRYPTION
┌──────────────────────────────────────────────────────────────────┐
│  In Transit: TLS 1.3 for all connections                         │
│  At Rest: AES-256 for storage                                    │
│  Application-level: Encrypt sensitive fields before storage      │
│                                                                  │
│  Key hierarchy:                                                  │
│  ┌──────────────────────────────────────────────────────┐        │
│  │  Master Key (HSM) → never leaves hardware            │        │
│  │       │                                              │        │
│  │       ▼                                              │        │
│  │  Data Encryption Key (DEK) → encrypts actual data    │        │
│  │  (DEK encrypted by Master Key, stored alongside data)│        │
│  └──────────────────────────────────────────────────────┘        │
└──────────────────────────────────────────────────────────────────┘

2. DATA MASKING & TOKENIZATION
┌──────────────────────────────────────────────────────────────────┐
│  Tokenization: Replace sensitive data with non-sensitive token   │
│                                                                  │
│  Original: 4532-1234-5678-9012 (credit card)                     │
│  Token:    tok_abc123xyz                                         │
│  Mapping stored in secure token vault                            │
│                                                                  │
│  Masking: Show partial data                                      │
│  SSN: ***-**-6789                                                │
│  Email: j***@example.com                                         │
└──────────────────────────────────────────────────────────────────┘

3. ACCESS CONTROLS
┌──────────────────────────────────────────────────────────────────┐
│  RBAC (Role-Based Access Control):                               │
│    Doctor → read patient records in their department             │
│    Nurse → read vitals, update medications                       │
│    Admin → manage users, no patient data access                  │
│                                                                  │
│  ABAC (Attribute-Based Access Control):                          │
│    Allow IF:                                                     │
│      user.department == patient.department                       │
│      AND user.role IN ['doctor', 'nurse']                        │
```

```
│      AND time.current BETWEEN shift.start AND shift.end        │
└─────────────────────────────────────────────────────────────────┘
```

GDPR Compliance Features

```
1. RIGHT TO ACCESS (Data Portability)
┌─────────────────────────────────────────────────────────────────┐
│  User requests: "Give me all my data"                           │
│  System: Export all PII in machine-readable format (JSON)       │
│  Timeline: Within 30 days                                       │
└─────────────────────────────────────────────────────────────────┘

2. RIGHT TO BE FORGOTTEN (Data Deletion)
┌─────────────────────────────────────────────────────────────────┐
│  User requests: "Delete all my data"                            │
│  System:                                                        │
│    1. Delete from primary database                              │
│    2. Delete from backups (within retention period)             │
│    3. Delete from analytics/logs (or anonymize)                 │
│    4. Notify third parties to delete                            │
│    5. Generate deletion certificate                             │
│                                                                 │
│  Exceptions: Legal holds, regulatory requirements               │
└─────────────────────────────────────────────────────────────────┘

3. CONSENT MANAGEMENT
┌─────────────────────────────────────────────────────────────────┐
│  Track consent per purpose:                                     │
│    - Marketing emails: Yes (2024-01-15)                         │
│    - Analytics: No                                              │
│    - Third-party sharing: Yes (2024-01-15)                      │
│                                                                 │
│  Respect consent in all data processing                         │
└─────────────────────────────────────────────────────────────────┘
```

Audit Logging

```
AUDIT LOG ENTRY:
{
  "timestamp": "2024-01-15T14:30:00Z",
  "actor": {
    "user_id": "user_123",
    "role": "doctor",
    "ip_address": "10.0.1.50",
    "session_id": "sess_abc"
  },
  "action": "READ",
  "resource": {
    "type": "patient_record",
    "id": "patient_456",
```

```
    "fields_accessed": ["name", "diagnosis", "medications"]
  },
  "context": {
    "reason": "treatment",
    "department": "cardiology"
  },
  "result": "SUCCESS"
}

REQUIREMENTS:
  - Immutable (write-once storage)
  - Tamper-evident (cryptographic chaining)
  - Retained for 7 years (HIPAA)
  - Searchable for investigations
```

Data Residency

```
MULTI-REGION DATA ISOLATION:
┌─────────────────────────────────────────────────────────────────┐
│                                                                 │
│  EU Users ──────────────▶ EU Region (Frankfurt)                 │
│                           └── EU data stays here                │
│                                                                 │
│  US Users ──────────────▶ US Region (Virginia)                  │
│                           └── US data stays here                │
│                                                                 │
│  Routing based on:                                              │
│    - User's country (from profile)                              │
│    - Legal entity                                               │
│    - Data classification                                        │
│                                                                 │
│  Cross-border: Only with explicit consent + legal basis         │
└─────────────────────────────────────────────────────────────────┘
```

Trade-offs

Decision	Option A	Option B	Recommendation
Encryption	DB-level	Application-level	**Application** - more control
Key storage	Software	HSM	**HSM** - for regulated data
Deletion	Hard delete	Soft delete + purge	**Soft + scheduled purge**
Logging	Minimal	Comprehensive	**Comprehensive** - compliance

Technologies Deep Dive

📚 **Learn more about the key technologies used in this design:**

Technology	Role in This Design	Reference
HSM	Hardware-based master key storage for encryption key hierarchy	Tech Guide

How to Explain It Well

> **Opening**: "Data security requires defense in depth: encryption, access control, and audit logging. I'll design for GDPR and HIPAA compliance."

> **Key talking points**:
>
> - "Encrypt sensitive fields at application level, keys in HSM"
> - "Tokenization for payment data - actual numbers never stored"
> - "RBAC + ABAC: role defines base access, attributes refine it"
> - "Right to be forgotten: cascading delete with certificate"
> - "Immutable audit logs with 7-year retention for HIPAA"
